

GESTION DES DONNÉES

INDICE A / 112 MAI 2025

INTRODUCTION

Cette section détaille les mécanismes mis en place pour structurer, traiter, stocker et sécuriser les données des utilisateurs, dans le respect strict des normes en vigueur telles que le RGPD.

Elle définit les modèles de données, les règles de validation, les exigences de stockage, les dispositifs de sauvegarde, ainsi que les mesures assurant la conformité et la protection des informations sensibles. Ce cadre garantit non seulement la fiabilité du système, mais aussi la confiance des utilisateurs.

CONFORMITÉ A LA PROTECTION DES DONNÉES (RGPD)

L'application sera conçue pour être pleinement conforme au Règlement Général sur la Protection des Données (RGPD), applicable à tous les utilisateurs résidant dans l'Union Européenne. Les mesures suivantes seront mises en œuvre pour garantir la protection des données personnelles.

Collecte et consentement

- Lors de l'inscription, l'utilisateur devra accepter explicitement la politique de confidentialité via une case à cocher non pré-cochée.
- Le consentement sera journalisé avec la date et l'heure, et pourra être révoqué à tout moment depuis les paramètres du compte.

Données personnelles collectées

Les données suivantes seront considérées comme personnelles et seront stockées dans la base de données :

- Identité : `email`, `username`
- Sécurité : `password_hash` (hashé avec `bcrypt` ou équivalent)
- Activité : `signup_date`, `level_id`, `points`, `badges`
- Participation : données liées aux parties (`game_users`, `wallets`, `transactions`)

Droits des utilisateurs

L'application fournira une interface dédiée pour exercer les droits garantis par le RGPD :

- **Droit d'accès** : l'utilisateur pourra consulter toutes les données stockées à son sujet.
- **Droit de rectification** : possibilité de modifier nom, email, et autres informations personnelles.
- **Droit à l'effacement** : suppression complète du compte et de toutes les données personnelles associées.
- **Droit à la portabilité** : export des données dans un format standard (JSON ou CSV).
- **Droit d'opposition** : possibilité de désactiver les communications non essentielles (news, notifications, quiz...).

Limitation de conservation

- Le champ `signup_date` permettra d'évaluer la durée de conservation des données.
- Les comptes inactifs depuis plus de **2 ans** seront signalés pour suppression automatique (avec alerte préalable à l'utilisateur).
- Les données d'activité (comme les transactions ou réponses à des quiz) pourront être conservées de façon anonymisée pour des fins statistiques après suppression du compte.

Sécurité et anonymisation

- Tous les mots de passe seront **hachés** (jamais stockés en clair).
- Les connexions se feront via **HTTPS/TLS** pour protéger les données en transit.
- Des logs anonymes seront utilisés pour l'analyse de performance, sans stocker d'informations permettant d'identifier l'utilisateur.
- Les exports ou rapports utilisés à des fins internes (ex : analyse de progression des joueurs) utiliseront la pseudonymisation : les identifiants directs (`user_id`, `email`) seront remplacés par des identifiants anonymes.

Sous-traitants et hébergement

- Toutes les données seront hébergées dans l'Union Européenne.
- Tout sous-traitant (par ex. pour l'envoi d'e-mails ou de notifications push) sera sélectionné en fonction de sa conformité au RGPD et sera lié par un contrat de traitement de données (DPA - Data Processing Agreement).
- Budge

Sous-traitants et hébergement

- Toutes les données seront hébergées dans l'Union Européenne.
- Tout sous-traitant (par ex. pour l'envoi d'e-mails ou de notifications push) sera sélectionné en fonction de sa conformité au RGPD et sera lié par un contrat de traitement de données (DPA - Data Processing Agreement).

| EXIGENCES DE SAUVEGARDE ET DE RÉCUPÉRATION DES DONNÉES

Pour garantir la continuité de service, la résilience de l'application et la protection des données utilisateurs, une stratégie de sauvegarde robuste est mise en œuvre.

Elle repose sur les piliers suivants :

Sauvegardes automatiques de la base de données

- **Fréquence :**
 - Sauvegarde complète chaque semaine à de la base de données.
 - Sauvegardes incrémentielles tous les 3 jours, permettant une restauration rapide à un état récent sans perte significative.
- **Contenu sauvegardé :**

Toutes les tables critiques seront sauvegardées, incluant :

- `users, wallets, transactions, game_instances, user_answers, user_badges, notifications`

Plan de rétention

- **Durée de conservation :**
 - Sauvegardes hebdomadaires conservées 4 semaines
 - Snapshots conservés pendant 2 semaines.

Procédures de restauration automatisées

- Scripts de restauration testés mensuellement sur un environnement de test isolé.
- Le temps de restauration estimé sera de :
 - **< 15 minutes** pour une base légère (tests, développement)
 - **< 1 heure** pour une base de production avec contenu utilisateur.
- La restauration peut être déclenchée automatiquement :
 - En cas de détection d'anomalie critique (ex : corruption de données, crash applicatif)
 - Ou manuellement par un administrateur.

Tests de restauration réguliers

- Simulation de restauration réalisée chaque mois :
 - Vérification de l'intégrité des données restaurées.
 - Comparaison entre les données originales et restaurées.

Journalisation et suivi des opérations sensibles

- Les **modifications critiques** dans la base seront journalisées dans des tables ou systèmes dédiés :
 - Achats ou ventes (**transactions**)
 - Progrès utilisateur (quizz validé, gain de badge, montée de niveau)
 - Modifications de compte utilisateur
- Ces événements sont marqués par des **timestamps** précis et peuvent être utilisés pour un rollback partiel si nécessaire.
- Une **alerte est déclenchée** (via système de monitoring type Grafana/Alertmanager ou mail) en cas d'échec d'une sauvegarde ou d'une incohérence détectée.

Responsabilité et accès aux sauvegardes

- Les sauvegardes sont accessibles uniquement par les administrateurs autorisés.
- Un registre d'accès aux sauvegardes est conservé pendant un an.

| EXIGENCES DE STOCKAGE DES DONNÉES

L'application sera hébergée sur un serveur dédié sécurisé, administré par l'équipe projet.

Toutes les données seront stockées sur une base de données relationnelle, installée localement sur ce serveur (PostgreSQL).

Le serveur sera configuré pour respecter les bonnes pratiques de sécurité, d'isolement et de conformité RGPD.

Infrastructure d'hébergement

- Le serveur d'application et la base de données seront hébergés sur un même serveur ou sur deux machines distinctes sécurisées.
- Le serveur sera mis à jour régulièrement pour corriger les failles de sécurité.
- L'accès physique ou distant au serveur sera limité à l'équipe technique autorisée.

Base de données

- **Système de gestion** : PostgreSQL installé en local sur le serveur.
- **Isolation des environnements** : Environnement de production séparé des environnements de test ou développement.
- Accès via comptes utilisateurs restreints (un compte par service ou développeur, avec permissions limitées).

Sécurisation des données sensibles

- **Mots de passe utilisateurs** :
 - Stockés hashés avec **bcrypt** ou **argon2**, avec salage fort.
 - Aucun mot de passe en clair n'est jamais stocké.
- **Chiffrement des données sensibles** :
 - Données chiffrées au repos (niveau disque ou champs spécifiques dans la base).
 - Données chiffrées en transit via HTTPS pour les communications client-serveur.

- **Partitionnement logique** par utilisateur :
 - Tables structurées pour que les données utilisateur (transactions, quiz, portefeuilles, réponses, etc.) soient toujours liées à leur identifiant (`user_id`), empêchant tout croisement ou fuite entre comptes.

Accès et permissions

- Mise en place d'un role based access control côté backend :
- Rôles : utilisateur standard, modérateur, administrateur.
- Accès limité strictement à ce qui est nécessaire.
- Authentification par token pour sécuriser les API.

Localisation des données

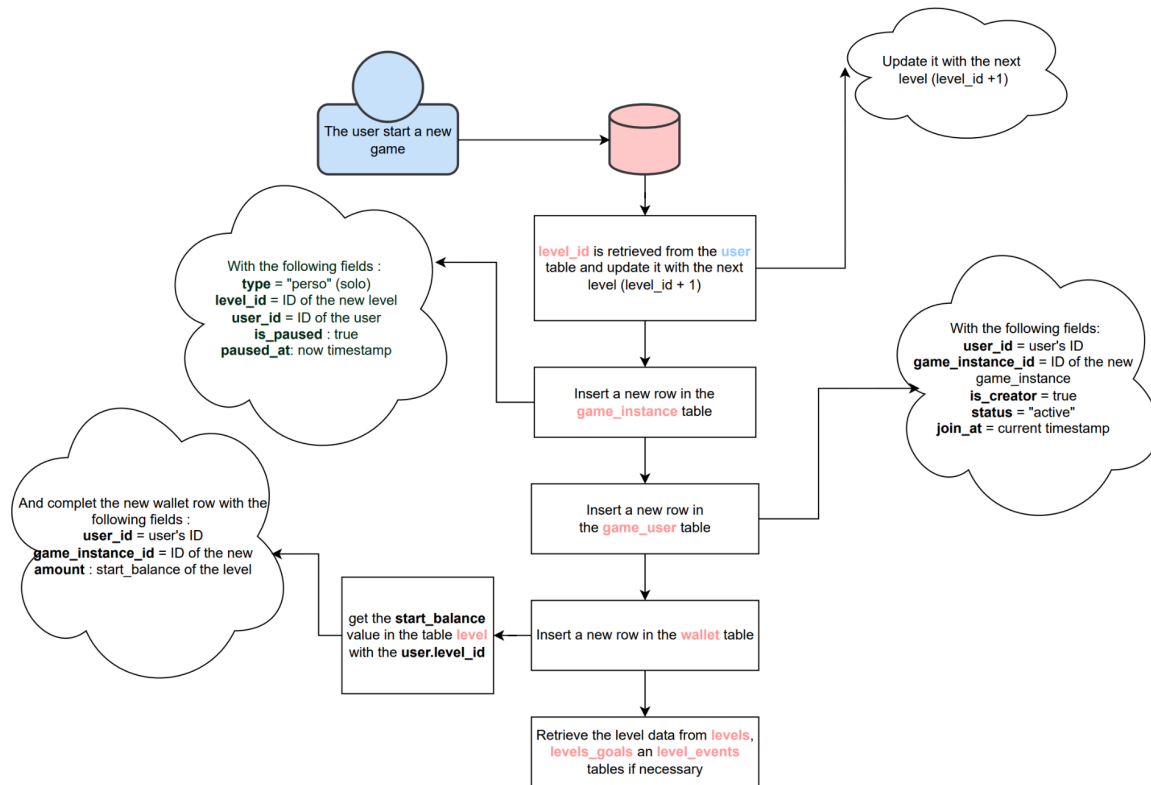
- Toutes les données sont stockées en France ou dans l'Union Européenne, pour respecter le RGPD.
- Le serveur est hébergé dans un datacenter physique conforme aux normes de sécurité (vidéosurveillance, accès badge, etc.).

Surveillance et maintenance

- Un système de **monitoring local** (type Uptime Kuma, Netdata, ou fail2ban/logwatch) est mis en place :
 - Pour détecter les connexions suspectes
 - Pour surveiller la charge, l'espace disque, et les erreurs serveur
- Les mises à jour système et applicatives sont effectuées manuellement ou par script sécurisé, avec backup préalable.

DIAGRAMME DES FLUX DE DONNÉES

Nouvelle Partie



The diagram illustrates a complex dependency graph, likely representing a module system or a package manager. It consists of numerous nodes, each represented as a small table with two columns: a name and a type. The nodes are interconnected by lines, forming a dense network of dependencies. The nodes are organized into a grid-like structure, with multiple columns and rows. The nodes are color-coded: blue for 'module', green for 'package', and yellow for 'package'. The graph shows a hierarchical structure of dependencies, with some modules depending on others, and some packages depending on other packages. The graph is a visual representation of the module dependency system in a programming language.

The nodes are organized into several sections, each representing a different module or set of modules. The nodes are color-coded: blue for 'module', green for 'package', and yellow for 'package'. The graph shows a hierarchical structure of dependencies, with some modules depending on others, and some packages depending on other packages. The graph is a visual representation of the module dependency system in a programming language.